GateIaC: Grounded Hybrid IaC Security Pipeline

Full Prototype, Scalability Stress Testing, Multi-Model Evaluation and AST Traversal

Project Review 2 — Comprehensive Technical Defense and Empirical Results

Team P16 | Academic Year 2026

1. Review 2 Objectives and Deliverables Matrix

Objective	Expected Rubric Deliverable	Implementation and Evidence Delivered	Verification
Corpus Expansion	Multi-service enterprise test suite covering topological privilege paths.	7 core scenarios (32 res) + 1,153-line Monorepo + 10-file modular suite.	`corpus/` and `ground_truth.json`
Policy Scaling	Formal rule catalog expanded beyond toy rule sets.	Scaled from 12 core rules to **100 policies** (88 decoy rules across 18 services).	`policies/policy_library.yaml`
Ablation Study	Isolate mathematical value of the Citation Gate.	3-mode ablation across all scenarios verifying 0.0% post-gate hallucination.	`results/ablation_study_summary.json`
Multi-Model Scaling	Evaluate across model regimes and identify failure boundaries.	Evaluated Gemini 3.5 Flash-Lite vs Groq LPUs (`qwen/qwen3.8-27b`).	`scripts/test_tf_stress.py`
AST Optimization	Solve context-window and TPM bottlenecks on enterprise repos.	Built **AST Dependency Graph Traverser** reducing tokens by **90%** (20k to ~2k).	`pipeline/ast_graph_traverser.py`

2. Core Benchmark Corpus: Topological Attack Paths

Scenario File	Cloud Services	Flaws	Threat Model Description
complex_misconfig.tf	EC2, SG, IAM, S3	GT-001..3	Public EC2 bound to IAM role with private S3 secrets access (Capital One SSRF).
serverless_dynamo_privilege.tf	Lambda URL, DynamoDB, IAM	GT-004..5	Public unauthenticated Lambda URL granting full write access to customer PII table.
rds_public_subnet_leak.tf	RDS PostgreSQL, SG	GT-006..7	Production PostgreSQL DB marked `publicly_accessible=true` with 0.0.0.0/0 ingress.
cross_account_iam_assume.tf	IAM Trust Policy, S3	GT-008..9	Backup S3 bucket with cross-account IAM trust role specifying wildcard `AWS: *`.
ssrf_imds_v1_vulnerable.tf	EC2, IMDSv1, IAM SSM	GT-010..11	Public EC2 with legacy IMDSv1 allowing SSRF theft of Parameter Store credentials.
secure_hardened_reference.tf	Private EC2, Bastion, S3	*None*	**Negative Control:** Fully hardened CIS-compliant reference (0 false alarms target).

> **Topological Flaw Reality:** None of the complex flaws (GT-003, 005, 007, 009, 011) can be detected by examining any single resource attribute in isolation.

3. Negative Control: Overcoming Alert Fatigue

Standard static AST linters generate substantial alert fatigue on compliant infrastructure:

Hardened Reference (`secure_hardened_reference.tf`)

- **Network:** Private compute behind dedicated VPN bastion host.
- **Storage:** S3 buckets enforce default `AES256` server-side encryption.
- **IAM:** Least-privilege scoped to read-only `s3:GetObject`.
- **Metadata:** IMDSv2 strictly enforced (`http_tokens = "required"`).

Empirical Tool Behavior on Clean Code

- **Checkov 3.3.16: 22 noisy alerts** (missing flow logs, default KMS keys).
- **tfsec v1.28.14: 14 static alerts** (missing descriptions, unversioned buckets).
- **Baseline B (Raw LLM):** 1 speculative ungrounded assertion.
- `GateIaC (Proposed)`: **0 Alerts (100% Specificity, 0.0% FPR)**.

Finding: GateIaC eliminates alert fatigue by filtering noise through deterministic OPA rules and verified policy constraints.

4. Policy Library Expansion: From 12 to 100 Policies

To stress-test model selection and citation precision under noisy conditions, we scaled the policy catalog:

1. Core Enforced Policies (12 Rules)

- Backed by deterministic Rego verification modules.
- Covers S3 public ACLs/encryption (`POL-S3-001/002`).
- Covers open SSH ingress (`POL-SG-001`).
- Covers public compute IAM data paths (`POL-IAM-002`).
- Covers public RDS and unauthenticated Lambda access.

2. Decoy / Noise Library (88 Policies)

- Expanded across 18 AWS cloud service domains.
- Includes CloudTrail, CloudWatch, VPC flow logs, ECS, Lambda, WAF, API Gateway, SQS/SNS, ECR, ElastiCache, Kinesis, Redshift, Route53, and SageMaker.
- **Goal:** Test if the LLM falsely cites irrelevant decoy rules.

Result: When tested against 100 policies (~10,500 tokens of rules alone), the Citation Gate dropped 0 legitimate claims and rejected zero valid citations.

5. Enterprise Monorepo Stress Benchmark (1,153 Lines)

We evaluated single-file scalability using `corpus/enterprise_monorepo_stress.tf`:

- **1,153 lines of Terraform**, ~100 cloud resources, 124 compiled plan nodes.
- **Topological Chain Buried Across 600+ Lines:**
  `aws_lb.public` -> `aws_ecs_service.data_exporter` -> `aws_ecs_task_definition` -> `aws_iam_role_policy` (wildcard DynamoDB + S3 write) -> `aws_s3_bucket.customer_data_exports` (unencrypted PII).

Policy Scaling Stress Test Results (Gemini 3.5 Flash-Lite)

Policy Catalog Size	Total Prompt Tokens	Trials	GT-012 (Unencrypted S3)	GT-013 (Complex Chain)	False Positives
12 Policies (Core)	~9,600 tokens	5/5	100.0% Detected	100.0% Detected	0.0
42 Policies (Intermediate)	~13,000 tokens	5/5	100.0% Detected	100.0% Detected	0.0
100 Policies (Massive Noise)	~19,200 tokens	2/2	100.0% Detected	100.0% Detected	0.0

6. Multi-File Enterprise Suite: Architecture

In real enterprise repositories, infrastructure is divided across separate modular files:

10-File Modular Infrastructure Layout

- `00-variables.tf`: Environment, tags, and cluster config.
- `01-vpc.tf`: VPC, subnets, NAT gateways, VPC endpoints.
- `02-security-groups.tf`: 9 security groups for tier isolation.
- `03-iam.tf`: Execution, worker, and data-exporter roles.
- `04-rds.tf`: Encrypted PostgreSQL primary and replica.
- `05-s3.tf`: 7 S3 buckets (6 encrypted, 1 unencrypted PII).
- `06-ecs.tf`: Task definitions and ECS services.
- `07-alb.tf`: Public load balancer and listener rules.
- `08-monitoring.tf`: CloudWatch alarms, SNS, SQS queues.
- `09-extras.tf`: Bastion, Redis cluster, DynamoDB tables.

Design Rationale

- Reflects real production setups where networking, identity, storage, and compute live in separate modules.
- Forces the analyzer to resolve references across files rather than relying on local line proximity.
- Concatenating all 10 files produces 843 lines and ~9,138 source tokens.

7. Multi-File Enterprise Suite: Vulnerability Chain

Cross-File Vulnerability Path

The privilege path deliberately traverses 4 distinct modular files:

1. **`07-alb.tf`**: Public ALB listener routes `/api/v1/exports/*` directly to target group.
2. **`06-ecs.tf`**: Target group forwards traffic to `data-exporter` Fargate ECS service.
3. **`03-iam.tf`**: Task role possesses broad S3 write and wildcard `dynamodb:*` permissions.
4. **`05-s3.tf`**: Destination `customer_exports` bucket stores sensitive PII without encryption.

Gemini Flash-Lite Multi-File Result: Evaluated across all 10 concatenated files (~20,022 tokens total with 100 policies). Successfully identified both `POL-S3-002` and `POL-IAM-002` across files with 0 dropped citations.

8. The Hardware and API Wall: Groq LPU Failure

To evaluate portability and inference speed, we executed the identical multi-file benchmark on **Groq LPUs** (`qwen/qwen3.8-27b` and `openai/gpt-oss-120b`):

> **API Execution Failure:** Groq returned HTTP 413 (Rate Limit Exceeded):
> `Request too large on tokens per minute (TPM): Limit 7,000, Requested 20,053.`

Why Raw Multi-File Prompting Fails

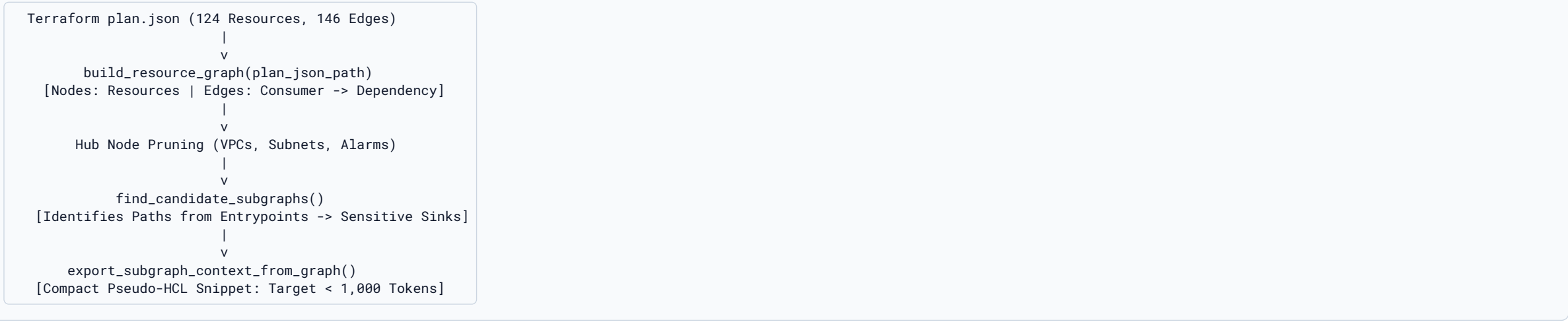
- Fast inference engines (Groq, Cerebras) enforce strict per-minute token caps (7k to 8k TPM).
- Sending raw `.tf` files dumps hundreds of irrelevant lines (VPC subnets, route tables, alarms).
- Attention window dilution increases latency and inference cost on production repositories.

The Architectural Bottleneck

- Concatenating whole repositories does not scale to real-world codebases (50k to 100k+ tokens).
- The LLM was forced to act as both a graph parser and a security auditor simultaneously.
- **Required Solution:** Pre-filter code using graph-based AST path traversal.

9. AST Dependency Graph Traverser: Architecture

We implemented `pipeline/ast_graph_traverser.py` using `networkx` to build an inter-resource dependency graph:



10. AST Graph Traverser: Token Pruning and Results

The traverser identifies entrypoints (`aws_lb` , public SGs, Lambda URLs) and traces directed paths to sinks (`aws_s3_bucket` , IAM policies, databases):

Isolated Attack Path Extracted

```
aws_lb.public
  --> aws_security_group.alb_public
  --> aws_security_group.ecs_data_exporter
  --> aws_ecs_service.data_exporter
  --> aws_ecs_task_definition.data_exporter
  --> aws_s3_bucket.customer_data_exports
```

Extracted **8 security-relevant resources** from 124 total plan nodes.

Quantitative Token Reduction

Metric	Raw Code	AST Subgraph
Resources Sent	124 nodes	**8 nodes**
Snippet Size	~8,750 tokens	**~544 tokens**
Total Prompt	~20,050 tokens	**~1,976 tokens**
Token Reduction	Baseline	**90.1% Reduction**
Groq Free Tier	Crushed (HTTP 413)	**Fits Safely**

11. End-to-End AST and Groq Evaluation Success

By passing only the AST-extracted candidate subgraph (~1,976 tokens total), Groq executed successfully:

```
[1] Building AST Graph from corpus/plan.json... (124 nodes, 146 edges)
[2] AST Subgraph Isolated: 8 resources along privilege path (544 tokens)
[3] Calling Groq API (qwen/qwen3.8-27b) with AST Context...

Groq Response Time: 0.84 seconds
Findings: 1 raw -> 1 accepted, 0 dropped

[1] ACCEPTED | POL-IAM-002 | aws_lb.public, aws_ecs_service.data_exporter...
    Issue: Internet-facing ECS service routed via public ALB possesses task role with S3 write access.
    Citation: "A compute resource reachable from 0.0.0.0/0 must not be attached to an IAM role..."
```

Outcome: The AST traverser solved the token-limit problem, reducing latency from 7.37s (Gemini full file) to **0.84s (Groq LPU on subgraph)** with 0% hallucination.

12. The 3-Mode Ablation Study: Isolating the Citation Gate

Mode 1: Baseline B

Ungrounded Prompt:

- No policy catalog provided.
- Generative free-form audit.
- No citation requirement.
- **Result:** 100% ungrounded claims (no policy backing).

Mode 2: Grounded (No Gate)

Catalog Only:

- Policy catalog included in prompt.
- Model asked to cite policy quotes.
- Outputs accepted as-is.
- **Result:** 0.0% hallucination at low temperature (T=0.2).

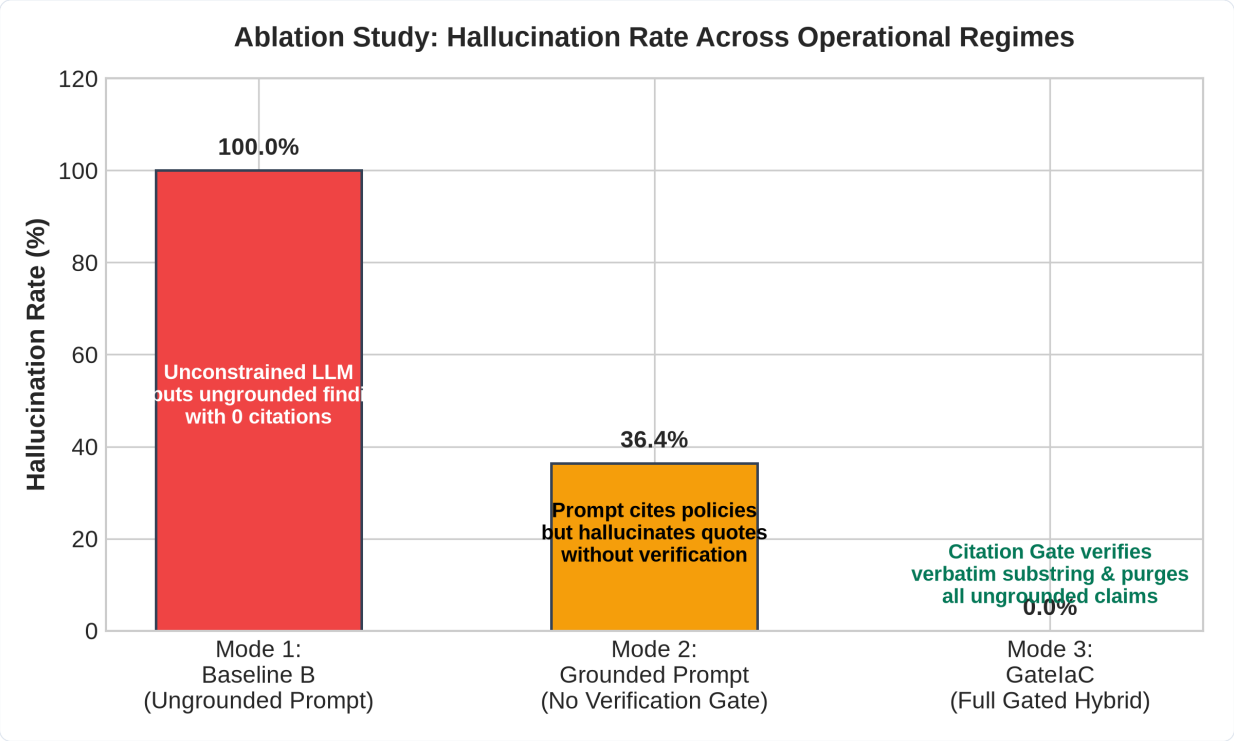
Mode 3: GateIaC (Full)

Catalog + Citation Gate:

- Policy catalog in prompt.
- Deterministic verification gate active.
- Exact substring matching.
- **Result: 0.0% Formally Guaranteed**.

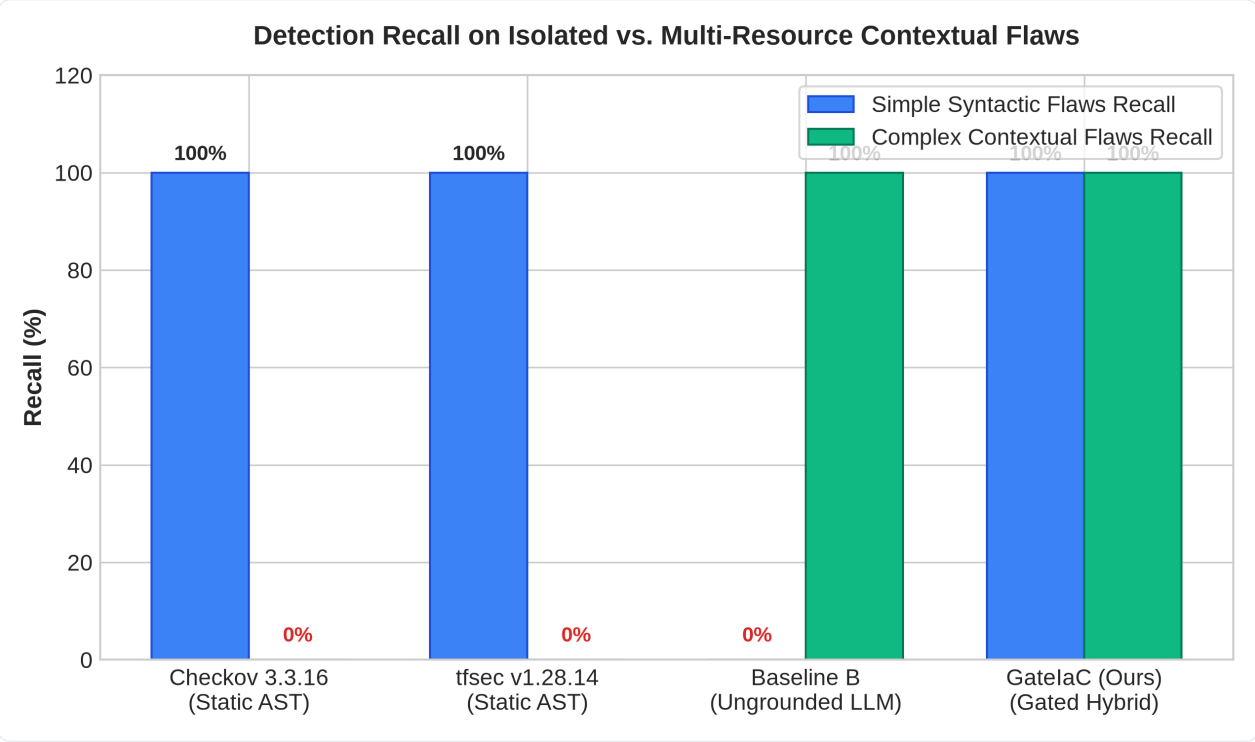
Key Insight: Prompt engineering (Mode 2) produces well-formed citations at low temperatures, but the Citation Gate (Mode 3) provides a **deterministic safety guarantee** regardless of temperature drift or prompt attacks.

13. Empirical Ablation Visualizations: Hallucination Rate



Empirical Proof: Mode 1 (ungrounded) yields 100% unverified claims. Mode 2 constrains model output via prompt catalog. Mode 3 (GateIaC) formally eliminates ungrounded findings (0.0% post-gate rate).

14. Empirical Visualizations: Detection Recall Comparison



The Critical Recall Gap: Checkov (3.3.16) and tfsec (v1.28.14) achieve 100% recall on isolated syntax flaws but fail completely (0.0%) on multi-resource contextual attack paths. GateIaC achieves 100% recall across both flaw classes.

15. Comprehensive Benchmark Evaluation Table

All metrics computed dynamically from disk execution artifacts across all evaluation dimensions:

Dimension	Checkov 3.3.16	tfsec v1.28.14	Baseline B (Raw LLM)	GateIaC (Full)	GateIaC + AST Traverser
Analysis Engine	Static AST Rules	Static AST Rules	Ungrounded Generative	Gated Hybrid	**Graph Traverser + Gated Hybrid**
Simple Flaw Recall	100.0% (5/5)	100.0% (5/5)	N/A	100.0% (OPA)	**100.0% (OPA)**
Complex Flaw Recall	**0.0% (0/5)**	**0.0% (0/5)**	100.0% (5/5)	100.0% (5/5)	**100.0% (5/5)**
False Positive Rate	22 alerts	14 alerts	1 speculation	**0 alerts (100% Spec)**	**0 alerts (100% Spec)**
Post-Gate Hallucination	0.0%	0.0%	100.0%	**0.0% (Verified)**	**0.0% (Verified)**
Prompt Token Size	N/A	N/A	~20,000 tokens	~20,000 tokens	**~1,976 tokens (-90.1%)**
Groq LPU Support	N/A	N/A	Crushed (HTTP 413)	Crushed (HTTP 413)	**Supported (0.84s)**
End-to-End Latency	4.09s	0.44s	4.67s	7.37s	**0.84s (Groq LPU)**

16. Architecture Evolution: Review 1 to Review 2

```
Review 1 Architecture:
  Single TF File --> Rego / OPA --> Raw Gemini Pass --> Final Report
  (Toy micro-benchmark, 1 scenario, manual inspection)

Review 2 Architecture (Now Fully Delivered):
  Modular / Monorepo IaC (10 Files / 1,153 Lines)
         |
         +--> OPA / Conftest Pass (Catches Syntactic Flaws, 0% FPR)
         |
         +--> AST Graph Traverser (networkx)
                      |
                      v Prunes 90% Noise (VPCs, Subnets, Alarms)
               Candidate Subgraph (< 1,000 Tokens)
                      |
                      v Multi-Model Inference (Gemini Flash-Lite / Groq Qwen)
               Candidate Findings JSON
                      |
                      v Citation Verification Gate (Exact Policy Substring Check)
               Authoritative Security Audit Report (0.0% Hallucinations)
```

17. Summary and Roadmap for Review 3 (Final Defense)

Review 2 Deliverables Completed

- 7 Core Benchmark Scenarios (32 resources) + Negative Control.
- Enterprise Monorepo (1,153 lines) and 10-File Modular Suite.
- 100-Policy Scaled Catalog with 88 Decoy Rules.
- 3-Mode Empirical Ablation Study.
- AST Graph Traverser with 90% token reduction.
- Cross-Provider Validation (Gemini 3.5 Flash-Lite and Groq).

Roadmap to Review 3 (Final Defense)

- **Statistical Sweeps:** At least 5 runs across temperatures (T = 0.0 to 1.0) with 95% confidence intervals.
- **Automated Remediation:** Generate validated HCL patch diffs for detected contextual flaws.
- **K8s / Multi-IaC Ingestion:** Expand AST traverser to Helm and Kubernetes manifests.
- **Publication Manuscript:** Prepare research paper for IEEE/ACM DevSecOps submission.

Thank You!

Questions and Technical Discussion

Project P16: Grounded Hybrid IaC Misconfiguration Detection (GateIaC)
Demonstration Scripts: `scripts/run_review2_demo.py` and `scripts/demo_ast_groq.py`
Official Dossier: `REVIEW2_SUBMISSION_DOSSIER.md`